

# CAHIER DES CHARGES

**CLIENT** : SOCIAL MEDIA AWARDS



**ENTREPRISE** : UNIVERSITÉ DE LORRAINE - IUT DE SAINT-DIÉ

AUDITEURS : TAS TOM, CESAR LUCAS

DATE : 22 FÉVRIER 2026



UNIVERSITÉ  
DE LORRAINE



Saint-Dié-des-Vosges

**PRÉSENTÉ PAR :**  
TAS TOM & CESAR LUCAS

# TABLE

## des matières

|                                           |    |
|-------------------------------------------|----|
| <b>1. CONTEXTE ET OBJECTIFS</b>           |    |
| 1.1 <u>CONTEXTE</u>                       | 3  |
| 1.2 <u>OBJECTIFS GÉNÉRAUX</u>             | 3  |
| <b>2. EXIGENCES FONCTIONNELLES</b>        |    |
| 2.1 <u>SÉCURITÉ (PRIORITÉ P0-P1)</u>      | 4  |
| 2.2 <u>PERFORMANCE (PRIORITÉ P1-P2)</u>   | 5  |
| 2.3 <u>ROBUSTESSE (PRIORITÉ P2-P3)</u>    | 6  |
| 2.4 <u>TESTS (PRIORITÉ P3)</u>            | 7  |
| 2.5 <u>CONFORMITÉ (PRIORITÉ P3)</u>       | 7  |
| 2.6 <u>CONTENEURISATION (OBLIGATOIRE)</u> | 7  |
| <b>3. EXIGENCES NON-FONCTIONNELLES</b>    |    |
| 3.1 <u>PERFORMANCE</u>                    | 8  |
| 3.2 <u>SÉCURITÉ</u>                       | 8  |
| 3.3. <u>ROBUSTESSE</u>                    | 8  |
| 3.4 <u>ACCESSIBILITÉ</u>                  | 8  |
| <b>4. LIVRABLE ATTENDUS</b>               | 9  |
| <b>5. PLANNING &amp; JALONS</b>           | 10 |
| <b>6. CRITÈRES D'ACCEPTATION</b>          | 11 |
| <b>7. CONDITIONS CONTRACTUELLES</b>       | 11 |

# 1.CONTEXTE ET OBJECTIFS

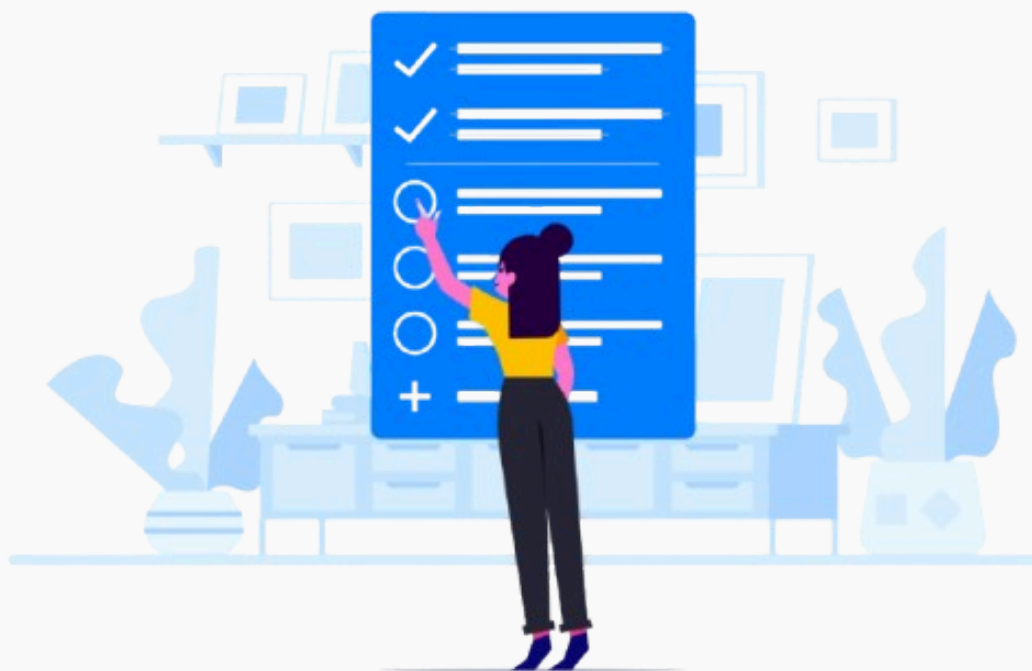
## 1.1 Contexte

À la suite de l'audit technique réalisé le 14 février 2026, 6 vulnérabilités critiques et 18 points d'amélioration majeurs ont été identifiés sur l'application Social Media Awards (PHP 8.2 + MySQL).

## 1.2 Objectifs Généraux

- **Sécurité** : Éliminer 100% des vulnérabilités critiques (P0-P1)
- **Performance** : Réduire temps chargement de 50%, requêtes SQL de 50%
- **Robustesse** : Refactorisation MVC complète + maintenabilité
- **Conformité** : RGAA 4 AA + RGPD
- **Déploiement** : Containerisation Docker

Date de livraison : **5 juin 2026**



# 2.EXIGENCES FONCTIONNELLES

## 2.1 Sécurité (Priorité P0-P1)

| ID | Exigence            | Critères d'acceptation                                                        |
|----|---------------------|-------------------------------------------------------------------------------|
| S1 | Protection uploads  | Validation MIME type serveur, .htaccess noPHP, hash stockage                  |
| S2 | Tokens CSRF         | Token unique/session sur 11 formulaires, régénération post-vote               |
| S3 | Rate limiting       | Blocage IP après 5 échecs, CAPTCHA essai 6+, cooldown 15min                   |
| S4 | Headers HTTP        | X-Frame-Options=DENY, CSP strict, HSTS 1an, nosniff                           |
| S5 | Sessions sécurisées | HttpOnly+Secure+SameSite=Strict, régénération post-login                      |
| S6 | Gestion erreurs     | display_errors=0 prod, logs structurés JSON<br>Analyse-de-l-existant-SAE4.pdf |
| S7 | Anonymat des votes  | Casser le lien User/Token dans la BDD (point critique de l'audit)             |

# 2.ANALYSE DES PERFORMANCES

## 2.2 Performance (Priorité P1-P2)

| ID | Exigence            | Critères d'acceptation                                                   |
|----|---------------------|--------------------------------------------------------------------------|
| P1 | SELECT * → colonnes | 0 SELECT * dans 23 fichiers                                              |
| P2 | Optimisation N+1    | LEFT JOIN getVotingCategoriesForUser(),<br><100ms/50 catégories          |
| P3 | Pagination          | LIMIT/OFFSET 20/page sur nominees/results,<br><100ms                     |
| P4 | Minification assets | CSS <50KB, JS <20KB, 0 règles<br>dupliquées                              |
| P5 | Gzip                | deflate activé, taille -70%                                              |
| P6 | Lazy loading        | loading="lazy" 24 images                                                 |
| P7 | Index MySQL         | 3 nouveaux index, comptage votes <50ms<br>Analyse-de-l-existant-SAE4.pdf |

# 2.ANALYSE DES PERFORMANCES

## 2.3 Robustesse (Priorité P2-P3)

| ID | Exigence            | Critères d'acceptation                      |
|----|---------------------|---------------------------------------------|
| R1 | Composer PSR-4      | composer install fonctionnel, autoload 100% |
| R2 | Front Controller    | /index.php?route=..., 0 URL codées dur      |
| R3 | Uniformisation BDD  | 100% noms ENG, 0 portugais/anglais mixte    |
| R4 | Logique → PHP       | 0 triggers métier, 2 procédures → Services  |
| R5 | URLs dynamiques     | BASE_URL partout, déployable n'importe où   |
| R6 | .env                | Identifiants hors Git, .env.example fourni  |
| R7 | Interfaces Services | 0 interfaces Contrôleurs                    |

# 2.ANALYSE DES PERFORMANCES

## 2.4 Tests (Priorité P3)

| ID | Exigence    | Critères d'acceptation |
|----|-------------|------------------------|
| T1 | PHPUnit 70% | 45+ tests              |

## 2.5 Conformité (Priorité P3)

| ID | Exigence     | Critères d'acceptation |
|----|--------------|------------------------|
| A1 | RGAA 4 AA    | WAVE audit 0 erreurs   |
| C1 | RGPD complet | Mentions légales       |

## 2.6 Conteneurisation (Obligatoire)

| ID | Exigence | Critères d'acceptation                             |
|----|----------|----------------------------------------------------|
| D1 | Docker   | docker-compose up fonctionnel,<br>PHP+Apache+MySQL |

# 3.EXIGENCES NON-FONCTIONNELLES

## 3.1 Performance

- Temps de chargement de la page d'accueil ~1s
- Requêtes SQL/page < 8
- Taille page <200KB zippé

## 3.2 Sécurité

- Open Worldwide Application Security Project (OWASP) Top 10 conforme
- 0 vulnérabilités critiques
- Logs audit 100% actions admin/vote

## 3.3 Robustesse

- PHPStan level 8
- 100% PSR-12
- 0 deprecated warnings PHP 8.2 (passage à la dernière version 8.5.3)

## 3.4 Accessibilité

- Référentiel Général d'amélioration de l'accessibilité (RGAA) 4 niveau AA (13 thématiques)
- Web Content Accessibility Guidelines (WCAG) 2.1 AA



# 4.LIVRABLE ATTENDUS

| Livrable        | Format             | Critères                                |
|-----------------|--------------------|-----------------------------------------|
| Code source     | GitLab             | 85h travail                             |
| Base de données | SQL dump           | meilleur indexation                     |
| Docker          | docker-compose.yml | docker-compose up fonctionnel           |
| Tests           | PHPUnit            | Couverture globale                      |
| Documentation   | README.md + docs/  | Installation, déploiement, contribution |
| Rapport         | PDF                | État avant/après, métriques             |
| Présentation    | PPT                | 12 juin soutenance                      |

# 5. PLANNING & JALONS

| Phase            | Date       | Livrables                   | Responsable |
|------------------|------------|-----------------------------|-------------|
| Phase 3          | 22/02/2026 | GitLab setup                | Tom         |
| Phase 4 Sprint 1 | 15/04/2026 | Sécurité 100%               | Tom/Lucas   |
| Phase 4 Sprint 2 | 29/04/2026 | Performance 100%            | Tom/Lucas   |
| Phase 4 Sprint 3 | 19/05/2026 | Robustesse 100%             | Tom/lucas   |
| Phase 4 Sprint 4 | 30/05/2026 | Tests/Conformité/<br>Docker | Tom/lucas   |
| Phase 4          | 05/06/2026 | Tous livrables              | Tom/lucas   |
| Phase 5          | 12/06/2026 | Soutenance orale            | Tom/lucas   |

# 6.CRITÈRES D'ACCEPTATION

## 6.1 Tests de Non-Régression

- 100% fonctionnalités existantes préservées
- Base jeu test : 600 comptes, 10 000 votes

## 6.2 Validation Client

- Revue code GitLab
- Tests UAT (User Acceptance Testing)
- Signature réception conforme

# 7.CONDITIONS CONTRACTUELLES

- **Référence devis** : 6 500€ HT
- **Support** : 1 mois post-livraison inclus
- **Garantie** : 6 mois sur fonctionnalités
- **Propriété intellectuelle** : Cession client après paiement intégral
- **Confidentialité** : signé par équipe

